FICTIONAL PROTOTYPE · Fictional organisation · Test-fixture figures, not an approved score · Not a certified paid report

MK FRAUD INSIGHTS

COMPREHENSIVE FRAUD READINESS REPORT

Fraud schemes, target control environment and implementation programme

10 of 49 applicable fraud schemes have a control reported as a gap.

78.5

CALCULATED FIGURE / 100

STRUCTURED

BAND OF THE CALCULATED FIGURE

A test fixture, not an approved score or readiness conclusion.

PREPARED FOR

Fictional Owner-Managed Firm

Assessment reference · FX-P4

CONFIDENTIAL · AUTOMATED ANALYSIS · NOT INDEPENDENTLY REVIEWED

HOW TO READ THIS REPORT

Contents

Management report	SECTIONS 1–9
1 · Where the organisation stands	
2 · What is driving the position	
3 · Where the material fraud exposure sits	
4 · Fraud scenario portfolio	
5 · The control environment management should build	
6 · Who must own the response	
7 · Decisions leadership must make	
8 · What should happen, and in what order	
9 · How management will know it is working	

Registers	APPENDICES A–I
A · Finding register	11 entries
B · Fraud risk register	10 entries
C · Control blueprint register	15 entries
D · Records management should maintain	9 entries
E · Action register	24 entries
F · Measurement register	15 entries
G · Answer relationships	1 entries
H · Outstanding information	0 entries
I · Roles used in this report	5 entries

THE TWO HALVES OF THIS REPORT

Sections 1–9 are the management report. The appendices hold every scheme, risk, control, record, action, measure, answer relationship and outstanding answer behind it, and the supporting workbook holds the same registers with the method references that trace each row to the question asked and the answer given.

BASIS OF THIS REPORT

This report is produced by fixed rules from the organisation's answers to the MK Fraud Readiness review, read against the draft review method, which MK has not yet approved. The AI manuscript stage has not been run; the interpretation in each section is fixed-rule text. No evidence has been examined, no control has been tested for operating effectiveness, no one has been interviewed and no assurance opinion is given. Records named in this report are records management should maintain; independent review of evidence is a separate Advisory service.

TEST FIXTURE

SECTION 1 · WHERE THE ORGANISATION STANDS

What the answers indicate

Each applicable fraud scheme, classified from the organisation's own answers. Nothing here has been tested or verified.

49
FRAUD SCHEMES THAT APPLY

37
CONTROLS THAT STOP THE SCHEME REPORTED IN PLACE

10
A CONTROL REPORTED AS A GAP

0
ANSWERS TO RESOLVE

0
ANSWERS OUTSTANDING

AREA	SCHEMES	IN PLACE	IN PLACE, FURTHER DEFENCE WEAKER	GAP	TO RESOLVE	NOT ANALYSED	CALCULATED FIGURE*
Digital, cyber-enabled and identity fraud	11	0	0	10	0	1	16.0
Ethics, integrity and anti-corruption	6	5	1	0	0	0	86.7
Fraud governance and accountability	11	11	0	0	0	0	90.0
Fraud risk assessment	6	6	0	0	0	0	91.7
Finance, banking and financial reporting	6	6	0	0	0	0	100.0
Detection, speak-up and response	8	8	0	0	0	0	86.7
Assets, cash and inventory	1	0	0	0	0	1	Not shown

Not analysed: 2 the method does not ask of an organisation of this size.

* Calculated figure 78.5 / 100 (Structured). TEST FIXTURE: hypothetical research value (scoring-frame simulation, Option A, midpoint, equal areas, no caps). Not an approved score, band or rating.

WHAT THIS MEANS

37 of the 49 schemes have the controls that stop them reported in place; in 1 of these a further defence is reported weaker, which does not change the answer given for the control. 10 have a control reported as a gap, 4 of them in tier 1, the schemes the draft method confirms in its core stage. The tier says how early the method asks about a scheme; it is not a rating of how serious it is. The core stage is complete and the breadth stage complete; 47 of the 47 schemes asked about can be analysed in full from the answers given.

SECTION 2 · WHAT IS DRIVING THE POSITION

The patterns behind the answers

Answers to resolve first, then requirements that span several areas, then where the gaps concentrate.

Where the gaps concentrate

AREA	SCHEMES WITH A GAP	OF WHICH TIER 1	SCHEMES IN THE AREA
Digital, cyber-enabled and identity fraud	10	4	11

The schemes themselves are listed by area in Section 3.

> **WHAT THIS MEANS**
>
> Of the 10 schemes with a control reported as a gap, most of them in digital channels. This is a count of schemes, not a rating of their seriousness.

SECTION 3 · WHERE THE MATERIAL FRAUD EXPOSURE SITS

Open and unresolved fraud schemes

Every scheme with a control reported as a gap or answers to resolve, grouped by area. MK has not yet approved a method for rating fraud risks, so no likelihood, impact or priority is assigned. Each scheme's risk statement is in Appendix B and its finding in Appendix A.

AREA	OPEN	SCHEMES (TIER 1 IN BOLD; ANSWERS TO RESOLVE MARKED)
Digital, cyber-enabled and identity fraud	10	**An email account is taken over** S01; **A payment instruction received by email is acted on** S02; **A cloned voice or video instruction is obeyed** S03; **A security compromise is not notified** S04; A help desk reset hands an attacker access S05; Systems that move money are accessed without strong sign-in S06; Personal information is over-exposed or kept too long S07; A compromise is not contained quickly S08; Spoofed email in the organisation's name deceives staff, suppliers or customers S09; The organisation's own information helps attackers S10

A further 1 scheme has the control that stops it reported in place with a further defence weaker. These are not open schemes; they are in Appendix A and their practices in Appendix C.

> **WHAT THIS MEANS**
>
> 10 schemes are open or unresolved across 1 areas, 4 of them in tier 1. The grouping shows where the work sits; it does not rank the schemes, and Section 7 asks management to decide the order.

SECTION 4 · FRAUD SCENARIO PORTFOLIO

How the schemes would work here

Plausible pathways for an organisation with the controls it reported, using the method's own description of each scheme. They are not allegations that any event has occurred.

An email account is taken over

S01 · DIGITAL CHANNELS · TIER 1

HOW IT STARTS	A mailbox without strong sign-in is used to send or intercept payment instructions.
WHY IT MATTERS	Most business email compromise starts with an account that has no multi-factor authentication.
WHAT THE ANSWERS SHOW	Multi-factor on all email: email accounts are protected by passwords only.
WHAT WOULD INTERRUPT IT	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.
WARNING SIGNS	Takeover of staff accounts; Business email compromise and payment redirection
LINKS	F01, FR01, C01

A payment instruction received by email is acted on

S02 · DIGITAL CHANNELS · TIER 1

HOW IT STARTS	Changed details or urgent payments are processed on the strength of an email.
WHY IT MATTERS	Acting on payment instructions received by email is how business email compromise succeeds.
WHAT THE ANSWERS SHOW	Email never enough on its own: payment changes received by email are acted on as received.
WHAT WOULD INTERRUPT IT	An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.
WARNING SIGNS	Business email compromise and payment redirection
LINKS	F02, FR02, C02

A cloned voice or video instruction is obeyed

S03 · DIGITAL CHANNELS · TIER 1

HOW IT STARTS	A caller who sounds or looks like a known person is believed.
WHY IT MATTERS	Voices and faces can be cloned, so only an agreed verification method holds.
WHAT THE ANSWERS SHOW	Verification for calls, voice notes and video: some staff check unusual requests, depending on their own judgement. Behind it, pressure triggers verification is partly in place, changes to call-back details verified is partly in place and gift cards and PIN requests banned is partly in place.
WHAT WOULD INTERRUPT IT	An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it.
WARNING SIGNS	Deepfake voice and video impersonation of executives and staff
LINKS	F03, FR03, C03, C04, C06, C05

A security compromise is not notified

S04 · DIGITAL CHANNELS · TIER 1

HOW IT STARTS	The Regulator and affected people are not told, so they cannot protect themselves.
WHY IT MATTERS	POPIA section 22 requires notification as soon as reasonably possible.
WHAT THE ANSWERS SHOW	Compromises reported as POPIA requires: a compromise would be handled as it happens, without a set process. Behind it, affected people warned is not in place.
WHAT WOULD INTERRUPT IT	A procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.
WARNING SIGNS	Theft and sale of personal information
LINKS	F04, FR04, C07, C08

A help desk reset hands an attacker access

S05 · DIGITAL CHANNELS · TIER 2

HOW IT STARTS	An impersonator persuades the help desk to reset a password or authenticator.
WHY IT MATTERS	The method links it to social engineering of the IT help desk and takeover of staff accounts.
WHAT THE ANSWERS SHOW	Help desk resets verified: most resets need verification through a trusted route, such as the person's manager or a number on file.
WHAT WOULD INTERRUPT IT	Every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.
WARNING SIGNS	Social engineering of the IT help desk; Takeover of staff accounts
LINKS	F05, FR05, C09

Systems that move money are accessed without strong sign-in

S06 · DIGITAL CHANNELS · TIER 2

HOW IT STARTS	Remote access, cloud or banking systems rely on passwords alone.
WHY IT MATTERS	The method links it to takeover of staff accounts.
WHAT THE ANSWERS SHOW	Multi-factor on critical systems: these systems are protected by passwords only.
WHAT WOULD INTERRUPT IT	It is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.
WARNING SIGNS	Takeover of staff accounts
LINKS	F06, FR06, C10

4 further open schemes are described in Appendices A and B.

SECTION 5 · THE CONTROL ENVIRONMENT MANAGEMENT SHOULD BUILD

Target controls, by programme

One programme for each accountable role. Each control is described in full once, in Appendix C, with the draft method's standard; here it is named with its reference and what it is for.

IT lead

7 CONTROLS

STOPS	an email account is taken over, a payment instruction received by email is acted on, a security compromise is not notified, a help desk reset hands an attacker access, systems that move money are accessed without strong sign-in, a compromise is not contained quickly and spoofed email in the organisation's name deceives staff, suppliers or customers.
PUT IN PLACE	Multi-factor on all email (C01, not in place); Email never enough on its own (C02, not in place); Compromises reported as POPIA requires (C07, partly in place); Help desk resets verified (C09, partly in place); Multi-factor on critical systems (C10, not in place); Compromise playbook (C12, not in place); Domain protected against spoofing (C13, partly in place).

Chief financial officer

4 CONTROLS

STOPS	a cloned voice or video instruction is obeyed.
PUT IN PLACE	Verification for calls, voice notes and video (C03, partly in place).
STRENGTHEN	3 further defences reported weaker behind a control reported in place or a gap: C04, C05, C06 (Appendix C).

Commercial and customer lead

1 CONTROL

STOPS	the organisation's own information helps attackers.
PUT IN PLACE	Staff guided on what not to share (C14, not in place).

Legal and compliance lead

2 CONTROLS

STOPS	personal information is over-exposed or kept too long.
PUT IN PLACE	Access to personal information limited (C11, partly in place).
STRENGTHEN	1 further defence reported weaker behind a control reported in place or a gap: C08 (Appendix C).

HR and payroll lead

1 CONTROL

STRENGTHEN	1 further defence reported weaker behind a control reported in place or a gap: C15 (Appendix C).

> **WHAT THIS MEANS**
>
> 10 controls are to be put in place and 5 are further defences to strengthen. The method establishes no dependency among these controls. Where the method describes a control only by its in-place answer, Appendix C says so rather than adding detail the method does not contain.

SECTION 6 · WHO MUST OWN THE RESPONSE

Accountability by role

Roles, not individuals: the assessment does not identify people. The method suggests owners in many forms; this report uses one label per function, and Appendix I lists the method's wording behind each. Oversight: The owners, from the organisation's own governance answer.

ROLE	CONTROLS	SCHEMES	ACTIONS	ANSWERS TO RESOLVE OR OBTAIN
IT lead	7	7	8	None
Chief financial officer	4	1	5	None
Commercial and customer lead	1	1	2	None
Legal and compliance lead	2	2	3	None
HR and payroll lead	1	1	2	None
Chief executive	0	10	4	Names the accountable executives, decides the order of work and reports status to the owners.

SECTION 7 · DECISIONS LEADERSHIP MUST MAKE

The decision agenda

A recommended direction follows the method and the answers; the decision remains management's. No deadline is set: "when" states what each decision must come before.

REF	DECISION	WHY	RECOMMENDED DIRECTION	WHEN	IF DELAYED
D01	**Name one accountable executive for each area with open or unresolved schemes: digital channels (10).**	Each scheme needs one person with authority over the process, the system and the people involved.	The method suggests: IT lead for digital channels.	Before design work starts.	Open schemes have no owner and the controls that stop them stay unassigned.
D02	**Decide which open schemes to address first.**	The draft method does not yet rank fraud risks by likelihood or impact, so this report does not rank them. The tier shows how early the method confirms a scheme, not how serious it is.	Resolve conflicting answers and prerequisites first, as the method requires; order the rest using management's own knowledge of volumes, values and exposure.	Before design work starts.	Effort is spread across every scheme at once, or follows the order of this report, which is not a risk ranking.
D03	**Have the owners receive the status of the open and unresolved schemes at each of its meetings until each is closed, deferred with a reason or accepted.**	Regular reporting keeps the schemes visible to the people who can remove blockers.	A one-page status per scheme: owner, controls in place, controls outstanding, next step.	From the first meeting after this report.	Progress is not visible until the next assessment.

SECTION 8 · WHAT SHOULD HAPPEN, AND IN WHAT ORDER

The implementation programme

Six phases, ordered by what must be known and decided before controls are built. No dates are set from a scheme's tier or answers; management sets them. Every action is in Appendix E.

#	PHASE	PURPOSE	ACTIONS	INCLUDES
2	**Decide and assign**	Name who is accountable for each area, decide which open schemes to address in this cycle and approve the target designs.	3	Name the executive accountable for digital channels, where 10 schemes are open or unresolved. Decide which of the 10 schemes with a control reported as a gap to address in this cycle, and in what order. Approve the target designs for the selected schemes, using the method standards in the control register.
4	**Put the remaining controls in place**	The controls reported as gaps for the schemes management has selected.	10	Put in place: multi-factor on all email (C01). Put in place: email never enough on its own (C02). Put in place: verification for calls, voice notes and video (C03). 7 more in Appendix E.
5	**Strengthen further defences**	Practices reported weaker behind a control reported in place.	5	Strengthen: pressure triggers verification (C04). Strengthen: gift cards and PIN requests banned (C05). Strengthen: changes to call-back details verified (C06). 2 more in Appendix E.
6	**Operate, measure and report**	Run each control through a full cycle, check it against its success measure and report status to the oversight body.	6	Run the 7 controls owned by the IT lead through a full cycle and check each against its success measure. Run the 4 controls owned by the chief financial officer through a full cycle and check each against its success measure. Run the 2 controls owned by the legal and compliance lead through a full cycle and check each against its success measure. 3 more in Appendix E.

WHAT THIS MEANS

Phases 1 and 2 need no new control: they establish the facts, name owners and choose the order of work. No control in this report relies on another, as far as the method establishes, so phases 3 and 4 can run together. Phase 6 runs each control through a full cycle and reports status to the owners.

SECTION 9 · HOW MANAGEMENT WILL KNOW IT IS WORKING

Measures and reporting

Each control has one success measure, in the method's own terms (Appendix F). These are the signals management should expect once a control operates; they are not a claim that they exist today.

INDICATOR	TODAY	EXPECTED
Open schemes with a named owner and a recorded decision	None recorded (10 open)	Every open scheme selected, deferred with a reason or accepted
Controls meeting their success measure for a full cycle	Not measured	Each control put in place (10)
Status reported to the owners	Not yet	At each meeting until each scheme is closed, deferred or accepted

Measures by programme

PROGRAMME	MEASURES	EXAMPLE
IT lead	7	The position the method treats as in place holds for the period: domain protected against spoofing: in place.
Chief financial officer	4	Records for the period show this practice applied to every case in scope: pressure triggers verification.
Commercial and customer lead	1	Records for the period show this practice applied to every case in scope: staff guided on what not to share.
Legal and compliance lead	2	Records for the period show this practice applied to every case in scope: affected people warned.
HR and payroll lead	1	Records for the period show this practice applied to every case in scope: training on joining.

CONCLUSION

Fictional Owner-Managed Firm's answers show 37 schemes with the controls that stop them reported in place and 10 with a control reported as a gap. The order of the remaining work is management's decision, because the draft method does not yet rank fraud risks; this report sets out what each scheme needs, who owns it and how management will know it is working.

APPENDIX A

Finding register

Every scheme with a control reported as a gap, answers to resolve, or a further defence weaker. "What the answers show" is self-reported and has not been verified. A scheme with answers to resolve is not treated as covered until they are resolved; a further defence reported weaker does not change the answer given for the control that stops the scheme.

REF	SCHEME	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	LINKS
F01 S01	**An email account is taken over** Digital, cyber-enabled and identity fraud · tier 1 CONTROL REPORTED AS A GAP	Multi-factor on all email: email accounts are protected by passwords only. Answered by the respondent.	A mailbox without strong sign-in is used to send or intercept payment instructions. Most business email compromise starts with an account that has no multi-factor authentication.	FR01, C01
F02 S02	**A payment instruction received by email is acted on** Digital, cyber-enabled and identity fraud · tier 1 CONTROL REPORTED AS A GAP	Email never enough on its own: payment changes received by email are acted on as received. Answered by the respondent.	Changed details or urgent payments are processed on the strength of an email. Acting on payment instructions received by email is how business email compromise succeeds.	FR02, C02
F03 S03	**A cloned voice or video instruction is obeyed** Digital, cyber-enabled and identity fraud · tier 1 CONTROL REPORTED AS A GAP	Verification for calls, voice notes and video: some staff check unusual requests, depending on their own judgement. Supporting practices also reported weaker: pressure triggers verification (partly in place), changes to call-back details verified (partly in place) and gift cards and PIN requests banned (partly in place). Answered by the respondent and Finance.	A caller who sounds or looks like a known person is believed. Voices and faces can be cloned, so only an agreed verification method holds.	FR03, C03, C04, C06, C05
F04 S04	**A security compromise is not notified** Digital, cyber-enabled and identity fraud · tier 1 CONTROL REPORTED AS A GAP	Compromises reported as POPIA requires: a compromise would be handled as it happens, without a set process. Supporting practices also reported weaker: affected people warned (not in place). Answered by IT and information and the respondent.	The Regulator and affected people are not told, so they cannot protect themselves. POPIA section 22 requires notification as soon as reasonably possible.	FR04, C07, C08
F05 S05	**A help desk reset hands an attacker access** Digital, cyber-enabled and identity fraud · tier 2 CONTROL REPORTED AS A GAP	Help desk resets verified: most resets need verification through a trusted route, such as the person's manager or a number on file. Answered by the respondent.	An impersonator persuades the help desk to reset a password or authenticator.	FR05, C09
F06 S06	**Systems that move money are accessed without strong sign-in** Digital, cyber-enabled and identity fraud · tier 2 CONTROL REPORTED AS A GAP	Multi-factor on critical systems: these systems are protected by passwords only. Answered by the respondent.	Remote access, cloud or banking systems rely on passwords alone.	FR06, C10
F07 S07	**Personal information is over-exposed or kept too long** Digital, cyber-enabled and identity fraud · tier 2 CONTROL REPORTED AS A GAP	Access to personal information limited: access is limited for some systems only. Answered by the respondent.	Too many people can reach or export personal information, or records outlive their purpose.	FR07, C11
F08 S08	**A compromise is not contained quickly** Digital, cyber-enabled and identity fraud · tier 2 CONTROL REPORTED AS A GAP	Compromise playbook: there is no plan; each case would be handled from scratch. Answered by the respondent.	Accounts stay compromised while suppliers and customers keep receiving instructions.	FR08, C12
F09 S09	**Spoofed email in the organisation's name deceives staff, suppliers or customers** Digital, cyber-enabled and identity fraud · tier 2 CONTROL REPORTED AS A GAP	Domain protected against spoofing: partly in place. Answered by the respondent.	Emails that appear to come from the organisation's own domain carry false payment instructions.	FR09, C13

REF	SCHEME	WHAT THE ANSWERS SHOW	HOW IT HAPPENS AND WHY IT MATTERS (METHOD)	LINKS
F10 S10	**The organisation's own information helps attackers** Digital, cyber-enabled and identity fraud · tier 3 CONTROL REPORTED AS A GAP	Staff guided on what not to share: reported as not in place. Answered by the respondent.	Published staff details and routines make impersonation easier.	FR10, C14
F11 S11	**Staff do not know or understand what is expected** Ethics, integrity and anti-corruption · tier 3 CONTROL IN PLACE; FURTHER DEFENCES WEAKER	Code accessible to staff: reported in place across everything it should cover. Further defences reported weaker: training on joining (partly in place). Answered by HR and payroll and the respondent.	Expectations are not communicated in a way people understand, and nobody checks.	C15

APPENDIX B

Fraud risk register

One risk for each open or unresolved scheme. No likelihood, impact, priority or monetary value is assigned: MK has not yet approved a method for rating them.

REF	RISK	CURRENT POSITION	TREATMENT	OWNER	RATING
FR01 F01	**A mailbox without strong sign-in is used to send or intercept payment instructions, because multi-factor on all email is not in place.** Most business email compromise starts with an account that has no multi-factor authentication.	Email accounts are protected by passwords only.	C01 Multi-factor on all email	IT lead	Not rated
FR02 F02	**Changed details or urgent payments are processed on the strength of an email, because email never enough on its own is not in place.** Acting on payment instructions received by email is how business email compromise succeeds.	Payment changes received by email are acted on as received.	C02 Email never enough on its own	IT lead	Not rated
FR03 F03	**A caller who sounds or looks like a known person is believed, because verification for calls, voice notes and video is partly in place.** Voices and faces can be cloned, so only an agreed verification method holds.	Some staff check unusual requests, depending on their own judgement.	C03 Verification for calls, voice notes and video; C04 Pressure triggers verification; C06 Changes to call-back details verified; C05 Gift cards and PIN requests banned	Chief financial officer	Not rated
FR04 F04	**The Regulator and affected people are not told, so they cannot protect themselves, because compromises reported as POPIA requires is partly in place.** POPIA section 22 requires notification as soon as reasonably possible.	A compromise would be handled as it happens, without a set process.	C07 Compromises reported as POPIA requires; C08 Affected people warned	IT lead	Not rated
FR05 F05	**An impersonator persuades the help desk to reset a password or authenticator, because help desk resets verified is partly in place.**	Most resets need verification through a trusted route, such as the person's manager or a number on file.	C09 Help desk resets verified	IT lead	Not rated
FR06 F06	**Remote access, cloud or banking systems rely on passwords alone, because multi-factor on critical systems is not in place.**	These systems are protected by passwords only.	C10 Multi-factor on critical systems	IT lead	Not rated
FR07 F07	**Too many people can reach or export personal information, or records outlive their purpose, because access to personal information limited is partly in place.**	Access is limited for some systems only.	C11 Access to personal information limited	Legal and compliance lead	Not rated
FR08 F08	**Accounts stay compromised while suppliers and customers keep receiving instructions, because compromise playbook is not in place.**	There is no plan; each case would be handled from scratch.	C12 Compromise playbook	IT lead	Not rated
FR09 F09	**Emails that appear to come from the organisation's own domain carry false payment instructions, because domain protected against spoofing is partly in place.**	Domain protected against spoofing: partly in place.	C13 Domain protected against spoofing	IT lead	Not rated
FR10 F10	**Published staff details and routines make impersonation easier, because staff guided on what not to share is not in place.**	Staff guided on what not to share: reported as not in place.	C14 Staff guided on what not to share	Commercial and customer lead	Not rated

APPENDIX C

Control blueprint register

Each control once, with every scheme it serves. The target standard and improving level are the draft method's own wording; "Reported today" is what the organisation answered. Where the method is not specific enough to say more, the row says so with the codes below rather than adding detail the method does not contain.

METHOD DETAIL CODES

- L The method describes this control only by its in-place answer; it has no level descriptions of what partial or full operation looks like.
- R The method names no records management should keep for this control.
- C The method does not say when or how often this control operates.
- I The method describes no level beyond in place for this control.

REF	CONTROL AND REPORTED TODAY	TARGET STANDARD (METHOD)	ACTIVITIES	OWNER, RECORDS, MEASURE
C01 Put in place S01	**Multi-factor on all email** Email accounts are protected by passwords only. Answered by the respondent.	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. Improving level: Phishing-resistant methods are used for high-risk accounts, and any account without multi-factor authentication is detected and fixed.	• Agree the design with the IT lead, so that it meets the target standard at level 4. • Keep the records in E01. • Review the first full cycle against M01.	IT lead E01, M01 Cycle: As the standard and question state
C02 Put in place S02	**Email never enough on its own** Payment changes received by email are acted on as received. Answered by the respondent.	An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it. Improving level: Compliance is checked, and the rule is tested through simulated requests.	• Agree the design with the IT lead, so that it meets the target standard at level 4. • Keep the records in E02. • Review the first full cycle against M02.	IT lead E02, M02 Cycle: As the standard and question state
C03 Put in place S03	**Verification for calls, voice notes and video** Some staff check unusual requests, depending on their own judgement. Answered by the respondent.	An agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it. Improving level: The method is tested, including with simulated deepfake calls, and staff are backed when they delay a senior request to verify it. Method detail: C	• Agree the design with the chief financial officer, so that it meets the target standard at level 4. • Keep the records in E03. • Review the first full cycle against M03.	Chief financial officer E03, M03 Cycle: Not stated by the method
C04 Strengthen S03	**Pressure triggers verification** Pressure triggers verification: reported in place only in some areas, cases or periods. Answered by Finance.	Pressure triggers verification: in place across everything it should cover. Method detail: L R C	• Agree the design with the chief financial officer, so that it meets the target standard. • Review the first full cycle against M04.	Chief financial officer M04 Cycle: Not stated by the method
C05 Strengthen S03	**Gift cards and PIN requests banned** Gift cards and PIN requests banned: reported in place only in some areas, cases or periods. Answered by Finance.	Gift cards and PIN requests banned: in place across everything it should cover. Method detail: L R C	• Agree the design with the chief financial officer, so that it meets the target standard. • Review the first full cycle against M05.	Chief financial officer M05 Cycle: Not stated by the method
C06 Strengthen S03	**Changes to call-back details verified** Most changes are verified through the old details or another trusted route. Answered by Finance.	Every change to a phone number or email used for verification is confirmed through the previous details or another trusted route before it is used. Improving level: Changes are logged and reviewed independently, and the holder of the old details is notified.	• Agree the design with the chief financial officer, so that it meets the target standard at level 4. • Keep the records in E04. • Review the first full cycle against M06.	Chief financial officer E04, M06 Cycle: As the standard and question state
C07 Put in place S04	**Compromises reported as POPIA requires** A compromise would be handled as it happens, without a set process. Answered by the respondent.	A procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly. Improving level: The procedure is tested, used after incidents and reviewed, and notification decisions are recorded. Method detail: C	• Agree the design with the IT lead, so that it meets the target standard at level 4. • Keep the records in E05. • Review the first full cycle against M07.	IT lead E05, M07 Cycle: Not stated by the method

REF	CONTROL AND REPORTED TODAY	TARGET STANDARD (METHOD)	ACTIVITIES	OWNER, RECORDS, MEASURE
C08 Strengthen S04	**Affected people warned** Affected people warned: reported as not in place. Answered by IT and information.	Affected people warned: in place across everything it should cover. Method detail: L R C	• Agree the design with the legal and compliance lead, so that it meets the target standard. • Review the first full cycle against M08.	Legal and compliance lead M08 Cycle: Not stated by the method
C09 Put in place S05	**Help desk resets verified** Most resets need verification through a trusted route, such as the person's manager or a number on file. Answered by the respondent.	Every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel. Improving level: Resets are logged and reviewed, and help desk staff are tested with simulated social engineering calls.	• Agree the design with the IT lead, so that it meets the target standard at level 4. • Keep the records in E06. • Review the first full cycle against M09.	IT lead E06, M09 Cycle: As the standard and question state
C10 Put in place S06	**Multi-factor on critical systems** These systems are protected by passwords only. Answered by the respondent.	It is required for remote access, cloud systems, the banking platform and every system that can move money or change master data. Improving level: Phishing-resistant methods are used where possible, and coverage is checked regularly.	• Agree the design with the IT lead, so that it meets the target standard at level 4. • Keep the records in E07. • Review the first full cycle against M10.	IT lead E07, M10 Cycle: As the standard and question state
C11 Put in place S07	**Access to personal information limited** Access is limited for some systems only. Answered by the respondent.	In every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged. Improving level: Access is reviewed regularly against roles, and unusual access or exports are alerted and investigated.	• Agree the design with the legal and compliance lead, so that it meets the target standard at level 4. • Keep the records in E08. • Review the first full cycle against M11.	Legal and compliance lead E08, M11 Cycle: As the standard and question state
C12 Put in place S08	**Compromise playbook** There is no plan; each case would be handled from scratch. Answered by the respondent.	A written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles. Improving level: The plan is tested, and it is updated after each test or incident. Method detail: C	• Agree the design with the IT lead, so that it meets the target standard at level 4. • Keep the records in E09. • Review the first full cycle against M12.	IT lead E09, M12 Cycle: Not stated by the method
C13 Put in place S09	**Domain protected against spoofing** Domain protected against spoofing: partly in place. Answered by the respondent.	Domain protected against spoofing: in place. Method detail: L R C	• Agree the design with the IT lead, so that it meets the target standard. • Review the first full cycle against M13.	IT lead M13 Cycle: Not stated by the method
C14 Put in place S10	**Staff guided on what not to share** Staff guided on what not to share: reported as not in place. Answered by the respondent.	Staff guided on what not to share: in place across everything it should cover. Method detail: L R C	• Agree the design with the commercial and customer lead, so that it meets the target standard. • Review the first full cycle against M14.	Commercial and customer lead M14 Cycle: Not stated by the method
C15 Strengthen S11	**Training on joining** Training on joining: reported in place only in some areas, cases or periods. Answered by HR and payroll.	Training on joining: in place across everything it should cover. Method detail: L R C	• Agree the design with the HR and payroll lead, so that it meets the target standard. • Review the first full cycle against M15.	HR and payroll lead M15 Cycle: Not stated by the method

APPENDIX D

Records management should maintain

The records the method names for each control, for management to keep as the control operates. MK has not requested, received or examined any of them. Independent review of evidence is a separate Advisory service; this report does not perform it.

REF	RECORD	CONTROLS	KEPT BY
E01	The email security report showing multi-factor status for every account, including shared mailboxes.	C01	IT lead
E02	The written rule, staff communication, call-back records for a sample of requests.	C02	IT lead
E03	The verification procedure, briefing records for executives, simulation results.	C03	Chief financial officer
E04	Change records for supplier and executive contact details, how each change was confirmed.	C06	Chief financial officer
E05	The breach response procedure, notification templates, records of past notifications.	C07	IT lead
E06	The help desk reset procedure, reset logs, social engineering test results.	C09	IT lead
E07	Multi-factor coverage reports for remote access, cloud and banking systems.	C10	IT lead
E08	Role-based access settings, export restrictions, access reviews.	C11	Legal and compliance lead
E09	The incident plan for email compromise, its contact list, test or incident records.	C12	IT lead

6 controls have no record named by the method; Appendix C marks them.

APPENDIX E

Action register

Every action in the programme, by phase. Phases follow what must be known and decided first; no dates are set.

REF	PHASE	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
A01	2. Decide and assign	Name the executive accountable for digital channels, where 10 schemes are open or unresolved.	Chief executive	A named accountable executive for the area.	The area has one named executive who has accepted the role.
A02	2. Decide and assign	Decide which of the 10 schemes with a control reported as a gap to address in this cycle, and in what order.	Chief executive	A recorded selection and order, with the reason for each choice.	Every open scheme is either selected, deferred with a reason, or accepted as a risk at the right level.
A03	2. Decide and assign	Approve the target designs for the selected schemes, using the method standards in the control register.	Chief executive	Approved designs, each with an owner and the records it will keep.	Each selected control has an approved design and an owner.
A04	4. Put the remaining controls in place	Put in place: multi-factor on all email (C01).	IT lead	C01 operating, keeping the records in E01.	M01 met for one full cycle.
A05	4. Put the remaining controls in place	Put in place: email never enough on its own (C02).	IT lead	C02 operating, keeping the records in E02.	M02 met for one full cycle.
A06	4. Put the remaining controls in place	Put in place: verification for calls, voice notes and video (C03).	Chief financial officer	C03 operating, keeping the records in E03.	M03 met for one full cycle.
A07	4. Put the remaining controls in place	Put in place: compromises reported as POPIA requires (C07).	IT lead	C07 operating, keeping the records in E05.	M07 met for one full cycle.
A08	4. Put the remaining controls in place	Put in place: help desk resets verified (C09).	IT lead	C09 operating, keeping the records in E06.	M09 met for one full cycle.
A09	4. Put the remaining controls in place	Put in place: multi-factor on critical systems (C10).	IT lead	C10 operating, keeping the records in E07.	M10 met for one full cycle.
A10	4. Put the remaining controls in place	Put in place: access to personal information limited (C11).	Legal and compliance lead	C11 operating, keeping the records in E08.	M11 met for one full cycle.
A11	4. Put the remaining controls in place	Put in place: compromise playbook (C12).	IT lead	C12 operating, keeping the records in E09.	M12 met for one full cycle.
A12	4. Put the remaining controls in place	Put in place: domain protected against spoofing (C13).	IT lead	C13 operating, with a record of each case it covers.	M13 met for one full cycle.
A13	4. Put the remaining controls in place	Put in place: staff guided on what not to share (C14).	Commercial and customer lead	C14 operating, with a record of each case it covers.	M14 met for one full cycle.
A14	5. Strengthen further defences	Strengthen: pressure triggers verification (C04).	Chief financial officer	C04 operating, with a record of each case it covers.	M04 met for one full cycle.
A15	5. Strengthen further defences	Strengthen: gift cards and PIN requests banned (C05).	Chief financial officer	C05 operating, with a record of each case it covers.	M05 met for one full cycle.
A16	5. Strengthen further defences	Strengthen: changes to call-back details verified (C06).	Chief financial officer	C06 operating, keeping the records in E04.	M06 met for one full cycle.
A17	5. Strengthen further defences	Strengthen: affected people warned (C08).	Legal and compliance lead	C08 operating, with a record of each case it covers.	M08 met for one full cycle.
A18	5. Strengthen further defences	Strengthen: training on joining (C15).	HR and payroll lead	C15 operating, with a record of each case it covers.	M15 met for one full cycle.

REF	PHASE	ACTION	OWNER	DELIVERABLE	COMPLETE WHEN
A19	6. Operate, measure and report	Run the 7 controls owned by the IT lead through a full cycle and check each against its success measure.	IT lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A20	6. Operate, measure and report	Run the 4 controls owned by the chief financial officer through a full cycle and check each against its success measure.	Chief financial officer	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A21	6. Operate, measure and report	Run the 2 controls owned by the legal and compliance lead through a full cycle and check each against its success measure.	Legal and compliance lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A22	6. Operate, measure and report	Run the 1 control owned by the commercial and customer lead through a full cycle and check each against its success measure.	Commercial and customer lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A23	6. Operate, measure and report	Run the 1 control owned by the HR and payroll lead through a full cycle and check each against its success measure.	HR and payroll lead	A first-cycle review for each control, with exceptions and their resolution.	Each control has met its success measure for one full cycle, or has a recorded correction.
A24	6. Operate, measure and report	Report the status of every open and unresolved scheme to the owners at each of its meetings until each is closed, deferred with a reason or accepted.	Chief executive	A one-page status: scheme, owner, controls in place, controls outstanding, next step.	The status is received and minuted at each meeting.

APPENDIX F

Measurement register

One success measure for each control, in the method's terms.

REF	MEASURE	CONTROL	OWNER
M01	Records for the period show that multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.	C01	IT lead
M02	Records for the period show that an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.	C02	IT lead
M03	Records for the period show that an agreed method, such as a call-back on a known number or a code word, applies to everyone, including executives, and staff know they are expected to use it.	C03	Chief financial officer
M04	Records for the period show this practice applied to every case in scope: pressure triggers verification.	C04	Chief financial officer
M05	Records for the period show this practice applied to every case in scope: gift cards and PIN requests banned.	C05	Chief financial officer
M06	Records for the period show that every change to a phone number or email used for verification is confirmed through the previous details or another trusted route before it is used.	C06	Chief financial officer
M07	Records for the period show that a procedure sets out who decides, who notifies the Information Regulator and the people affected, and how quickly.	C07	IT lead
M08	Records for the period show this practice applied to every case in scope: affected people warned.	C08	Legal and compliance lead
M09	Records for the period show that every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.	C09	IT lead
M10	Records for the period show that it is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.	C10	IT lead
M11	Records for the period show that in every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged.	C11	Legal and compliance lead
M12	Records for the period show that a written plan covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles.	C12	IT lead
M13	The position the method treats as in place holds for the period: domain protected against spoofing: in place.	C13	IT lead
M14	Records for the period show this practice applied to every case in scope: staff guided on what not to share.	C14	Commercial and customer lead
M15	Records for the period show this practice applied to every case in scope: training on joining.	C15	HR and payroll lead

APPENDIX G

Answer relationships

For each control reported fully in place, every practice of the same scheme reported weaker, not yet used or outstanding, and how the two answers relate. Only answers that cannot both be right, or a control relying on a weaker practice, leave the control unresolved. A further defence reported weaker does not change the answer given for the control; the reason for each classification is given.

SCHEME	CONTROL REPORTED IN PLACE	PRACTICE AND ITS ANSWER	RELATIONSHIP	WHAT IT MEANS
S11	**Code accessible to staff**	Training on joining: reported in place only in some areas, cases or periods.	FURTHER DEFENCE WEAKER Reviewed pair	Fraud and ethics training at joining is distinct from explaining conduct standards where employees work; induction is only one of the places Code accessible to staff names.

APPENDIX H

Outstanding information

Every question asked and not answered. A declined question, a question answered "I don't know" and a question still waiting are all outstanding; none is treated as answered.

No answer is outstanding.

APPENDIX I

Roles used in this report

Each consolidated role and the method's own suggested owners behind it.

ROLE IN THIS REPORT	METHOD WORDING
Chief financial officer	CFO and head of IT together
Commercial and customer lead	Communications or marketing manager
HR and payroll lead	HR or learning lead
IT lead	Head of IT or IT provider; Head of IT or information security
Legal and compliance lead	Information officer (POPIA)